DOCUMENTO DE ENTREGA TÉCNICA

Rede Krill Scheduling
Agendamento de coletas — backend, frontend e operação

Data desta edição: **2 de novembro de 2026** · Ramo: `main` · último commit publicado: `06cee93` · Estado do código de segurança: **modificado, aguardando commit de checkpoint pelo responsável**
Escopo: entrega de engenharia para uso interno, com inventário de controles, evidências medidas e lacunas residuais declaradas.

125 TESTES BACKEND · 0 FALHAS	**91,25%** LINHAS NOS 4 PACOTES CRÍTICOS (GATE 80%)	**0** VULNERABILIDADES DE PRODUÇÃO (NPM)
6 ADRS + RUNBOOK + RELATÓRIO DE SEGURANÇA	**Docker não validado** RUNTIME FORA DESTA MÁQUINA	**SCA backend não executado** DEPENDENCY-CHECK PENDENTE

1. Sumário executivo

O sistema cobre o fluxo completo de agendamento de coletas: autenticação com sessão revogável, cadastro e consulta de horários, tipos de caminhão e tipos de paletização, criação/movimentação/cancelamento de agendamentos com validação de capacidade, trilha de auditoria, relatórios paginados e notificação por e-mail via *outbox* transacional. A base anterior de segurança (token em `localStorage`, sem rotação, sem rate limiting) foi substituída por cookies `HttpOnly`, CSRF, refresh token rotativo, lockout de login e troca obrigatória de senha inicial.

> **Condição de entrega.** Pronto para operação interna controlada em instância única com HTTPS obrigatório. **Não** se afirma ausência de CVEs nas dependências backend (análise de composição nunca executada) nem validade do caminho Docker/CI (indisponível nesta máquina). As limitações estão listadas na seção 7 e amarradas a IDs em `SECURITY_REPORT.md`.

2. Inventário técnico

Camada	Tecnologia	Versão verificada	Evidência
Backend	Java + Spring Boot	21 / 4.1.2	`backend/pom.xml`
Persistência	Flyway + PostgreSQL + Hibernate	16-alpine · `ddl-auto: validate`	`docker-compose.yml`, `application.yml`
Autenticação	jjwt (JWT HS256) + BCrypt + refresh próprio	0.12.6	`JwtTokenService`, `AuthSessionService`

Camada	Tecnologia	Versão verificada	Evidência
Migrações	Flyway SQL versionado	V1–V6	`backend/src/main/resources/db/migration`
Frontend	Vue 3 + Vite + Pinia + Tailwind	Vite 8.3.5 · Vitest 5.1.0 · Playwright 1.64.1	`frontend/package.json`
Observabilidade	Actuator + Micrometer/Prometheus + logs ECS	—	`application-prod.yml`, `CorrelationIdFilter`
Qualidade	ArchUnit, JaCoCo (gate 80%), ESLint, Prettier, vue-tsc	JaCoCo 0.8.12	`ArchitectureTest`, `backend/pom.xml:170-192`
Entrega	Docker Compose (postgres, backend, frontend, MailHog em perfil `dev`)	—	`docker-compose.yml` — *não executado*

3. Arquitetura

Clean Architecture em quatro camadas com dependências apontando para dentro. Os limites são verificados por ArquUnit em `ArchitectureTest` (4 regras, executadas dentro dos 125 testes), o que impede que a camada de domínio dependa de Spring ou de detalhes de infraestrutura.

```
presentation (REST, DTOs, filtros, handler global) → application (use cases, ports, services, DTOs)
↓ ↓
infrastructure (JPA, Flyway, JWT, mail, outbox, seed) ← domain (entidades, políticas, repositórios-porta)
```

Decisões documentadas

ADR	Decisão	Consequência prática
ADR-001	Sessão = JWT curto + refresh opaco em cookie `HttpOnly`, com `sid` no access token	Logout e revogação têm efeito imediato; `localStorage` saiu do frontend
ADR-002	CSRF por `CookieCsrfTokenRepository` + exceção apenas para header `Bearer`	Mutações no navegador exigem `X-XSRF-TOKEN`; CLI dev continua funcionando
ADR-003	E-mail por outbox transacional, envio assíncrono e re-tentativas	POST nunca depende do provedor de e-mail; `emailQueued` ≠ `emailSent`
ADR-004	Limites de capacidade como constantes de domínio (480/dia, 120/faixa)	Sem tabela de configuração; `V5` removeu `capacity_settings`
ADR-005	Flyway como único dono do schema, `validate` em todos os perfis	Deploy de banco antes do de app; migração quebrada derruba o boot
ADR-006	Unicidade em três camadas + `@Version` para lock otimista	Concorrente recebe `409`, não escrita duplicada ou perdido

Fluxo de autenticação em uso

```
login → ensureCsrf (GET) → POST /api/auth/login → set cookies (access 15’ / refresh 7d, hash SHA-256 no banco)
expiração → 401 → fila single-flight no axios → POST /api/auth/refresh → rotação (token antigo revogado, de uso único)
troca de senha obrigatória → filtro devolve 403 PASSWORD_CHANGE_REQUIRED → /change-password revoga todas as sessões
```

4. Segurança implementada

Controle	Implementação	Local
Sessão revogável	Claim `sid` validado contra `auth_session`; `revokeIfActive` torna refresh de uso único	`AuthSessionService.java:48-137`, `JwtAuthenticationFilter.java:56-96`
Segredo de refresh	32 bytes de `SecureRandom`; persistido somente como hash SHA-256, com índice único	`SecureRefreshTokenGenerator.java:16-39`
CSRF	Cookie token repository + matcher de exceção para `Authorization: Bearer`	`SecurityConfig.java:56-65`
Lockout de login	5 tentativas por conta, 20 por IP, janela 15’, bloqueio 5’ progressivo (×4), poda a 10 000 entradas; `429` + `Retry-After`	`LoginAttemptService.java:40-114`
Política de senha	12+ caracteres, letra e número, lista de senhas proibidas; troca obrigatória no primeiro acesso; revoga sessões ao trocar	`ChangePasswordUseCase.java:20-95`, `PasswordChangeRequiredFilter`
Segredos obrigatórios	`JWT_SECRET` e `POSTGRES_PASSWORD` sem default; validador fail-fast no perfil `prod`	`ProductionConfigurationValidator.java:42-81`
Superfície exposta	health público sem detalhes; prometheus e Swagger só para ADMIN; Swagger desligado por default em produção	`SecurityConfig.java:121-136`, `application-prod.yml`
Auditoria	Trilha imutável com ator, entidade, ação e correlation id	`V4` / `V5`, `AuditLogController`
Frontend	`withCredentials`, nenhum token em storage, `safeRedirect` contra open redirect	`services/api.js`, `stores/auth.js`

5. Evidências medidas

Todos os números abaixo foram re-lidos nesta edição a partir dos artefatos gerados no repositório — não de memória. Nada aqui foi estimado.

Métrica	Valor	Origem	Status
Testes backend	125 em 25 classes · 0 falhas · 0 erros · 0 ignorados	`backend/target/surefire-reports/*.xml`	MEDIDO
Cobertura — gate crítico (linhas)	438/480 = **91,25%** contra mínimo de 80%	`backend/target/site/jacoco/jacoco.csv`	MEDIDO
Cobertura — gate crítico (instruções)	1966/2240 = **87,77%** (número citado em sessões anteriores)	mesmo CSV, contador `INSTRUCTION`	MEDIDO
Cobertura global	linhas 80,05% · ramos 56,93%	mesmo CSV	CONTEXTO
Classes de controle de acesso	`LoginAttemptService` 69,4% linhas / 57,4% instr · `ChangePasswordUseCase` 75,6% / 68,5% · `JwtTokenService` 72,7% linhas	mesmo CSV, por classe	LACUNA — SEC-02
Processador de outbox	`EmailOutboxProcessor` com 0% de linhas (49 linhas sem cobertura)	mesmo CSV	LACUNA — SEC-14
Dependências frontend — produção	`npm audit --omit=dev` → **found 0 vulnerabilities** (re-executado nesta edição)	`frontend/package-lock.json`	MEDIDO
Dependências frontend — dev	12 vulnerabilidades moderadas em árvore de desenvolvimento; sem efeito no bundle entregue	`npm audit` completo	ACEITO
E2E frontend	último run `"status": "passed"`, `"failedTests": []` (fluxo de autenticação)	`frontend/test-results/.last-run.json`	MEDIDO
Dependências backend (SCA)	sem relatório `dependency-check`; exige chave NVD	perfil `security` em `backend/pom.xml`	NÃO EXECUTADO — SEC-03
Docker Compose / CI GitHub Actions	arquivos presentes e revisados; nenhuma execução nesta máquina	`docker-compose.yml`, `.github/workflows/ci.yml`	NÃO VALIDADO — SEC-06

> **Precisão de número.** A métrica citada como "cobertura crítica 87,77%" corresponde a *instruções*. O gate do build é avaliado por *linhas*, cujo valor atual nos quatro pacotes críticos é 91,25%. Ambos os números são apresentados nesta entrega para evitar ambiguidade em revisões futuras.

6. Achados abertos (resumo)

Descrição completa, evidência e plano de re-teste em `SECURITY_REPORT.md`, seções 6 e 9.

ID	Criticidade	Achado	Estado
SEC-01	Alto	Lockout de login é local à instância (memória) — não compartilhado e zerado no restart	PARCIAL
SEC-03	Alto	Análise de composição do backend nunca executada; não é possível afirmar ausência de CVEs	ABERTO
SEC-06	Alto	Sem validação de runtime: Docker indisponível, CI nunca rodou sobre este estado, e2e cobre só autenticação	ABERTO
SEC-02	Médio	Gate por agregado de pacote oculta cobertura fraca exatamente nas classes de controle de acesso	ABERTO
SEC-04	Médio	Reuso de refresh token não dispara revogação em cascata nem evento de auditoria	ABERTO
SEC-05	Médio	Política de senha assimétrica: ADMIN cria com 8 caracteres, usuário troca exigindo 12	ABERTO
SEC-07	Baixo	Work factor do BCrypt fixo em 10, não parametrizável por configuração	ABERTO
SEC-08	Baixo	`email_outbox` retém destinatário e erros sem política de expurgo	ABERTO
SEC-09	Baixo	Credencial de fixture `LoginUseCaseTest.java:60,66,149` com aparência de segredo real	ABERTO
SEC-10/11/12	Info	`SameSite` divergente por perfil, token no corpo só em dev, CORS por lista explícita	INFORMATIVO
SEC-13	Baixo	Migração `V5` destrutiva (`DROP TABLE capacity_settings`) — justificada no SQL e no runbook	TRATADO
SEC-14	Médio	`EmailOutboxProcessor` sem teste próprio (0% de cobertura): a entrega assíncrona garantida pelo ADR-003 só existe como código	ABERTO

7. O que ainda não se pode afirmar

- **Ausência de CVEs no backend.** Nunca executado; requer `NVD_API_KEY` e o perfil Maven `security`.
- **Comportamento ponta a ponta dos controles.** CSRF, `429`, rotação de refresh e outbox são verificados por testes unitários e de integração com Postgres embarcado, não contra o stack completo do compose.
- **Deploy em produção.** Nenhum ambiente real recebeu esta versão; o checklist de go-live está em `docs/operacao/RUNBOOK.md`, seção 9.
- **Escala horizontal.** Rate limiting em memória e outbox sem *claim* distribuído limitam a réplica a uma instância ativa por restrição deliberada (SEC-01, ADR-003).

8. Entregáveis desta documentação

Artefato	Conteúdo
`README.md`	Visão, arquitetura, regras de negócio, execução sem Docker, variáveis de ambiente, API, migrações, testes e limitações
`SECURITY_REPORT.md`	Superfície por rota, 10 grupos de controles, evidências, 14 achados, mapa da auditoria anterior e plano de re-teste
`docs/arquitetura/`	Índice + ADR-001 a ADR-006, todos com status Aceita e evidência em arquivo:linha
`docs/operacao/RUNBOOK.md`	Perfis, provisionamento, rotinas com SQL real, deploy e rollback, incidentes, escalabilidade e diagnóstico
`docs/entrega/ENTREGA.html` · este PDF	Documento de entrega para revisão técnica e de negócio
`docs/entrega/ROTEIRO_VIDEO.md`	Roteiro cena a cena da demonstração, com falas, tempo e o que mostrar em tela
`docs/VALIDACAO_FINAL.md`	Relatório final de validação com itens classificados por criticidade e evidência

9. Recomendações por prioridade

Prioridade	Ação	Fecha
P0 antes do go-live	Executar Dependency-Check com chave NVD e triar; rodar o stack real via compose e validar login + CSRF + `429` + criação de agendamento ponta a ponta	SEC-03, SEC-06
P0 antes do go-live	Commit de checkpoint do estado atual e execução da CI sobre ele	SEC-06
P1 primeira iteração	Gate de cobertura por classe nas 4 classes de controle de acesso; testes de lockout progressivo, poda e do processador de outbox	SEC-02, SEC-14
P1 primeira iteração	Revogação em cascata no reuso de refresh + evento de auditoria; unificar política de senha em 12+ no cadastro e na troca	SEC-04, SEC-05
P2 conforme escala	Store compartilhado de tentativas de login (Redis ou tabela) quando houver mais de uma réplica; parametrizar BCrypt; retenção/expurgo de outbox e auditoria; secret-scan no repositório	SEC-01, SEC-07, SEC-08, SEC-09
